



**Qualys received
4.9 out of 5 stars
and a 95% willingness
to recommend.**

“Our overall experience with Qualys TotalCloud has been exceptional, providing robust multi-cloud security, seamless integration, and user-friendly interface that significantly enhances our cloud security management.”

- [Gartner Peer Insights](#)



Episode 1

Demystifying the CNAPP

Applying vulnerability management in the cloud-native world

Dave Introduction "Welcome everyone! Whether you're drowning in cloud security acronyms or just trying to figure out what CNAPP actually means, today we're cutting through the confusion."

"With me is Matt Campbell, who's helped many of our customer organizations figure out cloud security. Today we're going to explore some key questions about security in the cloud and help you understand the tools that can support your organisation improving its cloud security. By the end of session you'll be much clearer on CNAPP and why its important to you."

"Some ground rules for today: Drop questions in chat anytime. We'll address them as we go. We'll be taking some polls - its always interesting to get some direct insights into what's happening in the real world direct from our peers."

We won't be diving in too deep today – the idea is for a high level discussion of what is a CNAPP, why its important and what best practice look like. In our later episodes we will take a closer look at these principles, how the technologies work together and how to extend your programme to the teams around you.

"We'll be covering three focused questions today that come out of the discussions we have with customer organisations daily in the course of our work. By the end, you'll understand what cloud security best practice really means, what CNAPP actually is, and how a CNAPP helps you in your security and risk management operations. Then we'll finish with some practical guidance for your Monday morning priorities on your road to CNAPP adoption.

"Question 1"Let's start with the phrase everyone uses but are often a bit hazy on what it really means - 'security best practice.' I think many in the audience will have something in mind for what this means, no doubt informed by their own experience, but isn't it the case that traditional best practices can actually make you LESS secure when talking cloud? So what does best practice actually mean now?"

Thanks Dave for the introduction and welcome everyone to our first episode in our cloud security webinar series. Great to have you all here.

So, I'd like to start by challenging the idea that cloud security is fundamentally different to what we should be doing on-prem or anywhere else in our enterprise infrastructure. Much of the talk around changes in security practice when moving to the cloud has more to do with changes in our technology landscape and approaches to security in general, than with our deployment methods.

So perhaps a better way to think of this is: what does our current best thinking look like when talking cyber security today?

Personally, I direct anyone interested in studying this topic to read the mandates and standards, most of them are surprisingly readable and accessible. The NIST CSF, Cyber Security Framework, is a great place to start. I know, hardly bedtime reading, but it lays out very clearly an approach to security that serves us equally well in all domains, which is the purpose of it. To define security principles that can be applied, regardless of the technology that's deployed.

So, when talking cloud security what has driven change isn't so much the move to cloud platforms, but rather updated thinking about security in general.

The real shift is from static, manual security practices to dynamic, automated ones. From periodic validation to continuous verification. From human-scale administration to programmatic, automated security controls. Change is not unique to security, the same concepts drive other modern practices like CI/CD.

For beginners: "Think of it like the difference between manually checking every door in a building once a week versus having smart locks that verify every access attempt in real-time."

For intermediate practitioners: "The same defense-in-depth principles apply, but now we can implement them with Infrastructure as Code, API-driven monitoring, and event-driven responses. Automation basically"

Advanced perspective: "What we call 'cloud-native security' is really just modern security engineering - policy as code, immutable infrastructure, zero-trust architecture, moving to that "identity as the new perimeter" moving to continuous security automation and away from the fortress like mentality, supported by strong perimeters, checklists and processes that we used to use in the past.

So for our session today, we thought it was important to study some real world breaches so we can get a better understand of \

Breach Context: Large Financial Services Company, in 2019, quite a while ago, but it was major breach and a great case study a few different security principles.

Scale: 100 million US customers, 6 million Canadian customers affected, and it was extremely sensitive personal financial data, including credit scores and balances, payment histories and PII like social security numbers, addresses etc was leaked

Impact: \$700M+ in fines, congressional hearings, CEO resignation

"Here's how the attack worked: The attacker sent specially crafted requests to the companies misconfigured Web Application Firewall running on an EC2 instance, and spoofed it into making calls to AWS's EC2 metadata service instead of the legitimate backend services. The key point is, is that these metadata calls are now in the context of the EC2 instance itself, so the service was happy to hand over an EC2 IAM credential token to the compromised WAF. The attacker then used these stolen credentials to systematically access and download encrypted customer data from S3 buckets, data it could use the same IAM role to decrypt using calls to the AWS KMS, Key Management Service, an encryption key management tool in AWS."

5 "Capital One followed traditional best practice. Look what they had:"

WAF for perimeter security ✓

Security monitoring tools ✓

Compliance certifications ✓

Regular vulnerability scanning ✓

"But they missed some modern essentials:"

No continuous monitoring of their configuration, they had no visibility of the fact their WAF wasn't set up to prevent Server Side Request Forgery attacks by only allowing whitelisted backend URLs, or blocking unneeded IP ranges, basic App Firewall stuff

A basic cloud posture control, enabling IMDSv2 for AWS metadata service would have prevented this attack by forcing the WAF to run a token acquisition step to start a session with the metadata service, so it was able to assume the EC2s IAM role with a simple GET request to a local IP. I have to be fair to Capital One at this point, this breach was what put IMDS_v2 on the radar for the industry, so perhaps this part of the chain wasn't really their fault.

The over-permissioned IAM role (not least privilege for the job at hand) meant it could both access the S3 bucket and decrypt the data

I'd add in here, no lateral movement protection, why was the WAF even able to route to the S3 bucket, that should be something only an application can reach, a misconfig like point 1 really.

So what are the lessons here?

For beginners: "Limit things to only what is necessary for their task. This is such a brilliant example of why this principle is important. Why could the WAF route to the metadata service or S3 bucket at all? Did it need to be able to?

Advanced perspective: "Similarly, limiting permissions with tighter IAM roles would have prevented the attacker being able to access and decrypt the customer data. Finally, IMDSv2 enforcement would have blocked this entirely. This is why automated security controls are so important. Its not possible to catch things like this, at scale, without them."

In our CNAPP product, TotalCloud for example, you would get a CSPM alert on the IMDSv2 failure and immediately be able to see the IAM roles associated with the instance, its attached policies and permissions

So what does modern security implementation look like? I really like the AWS Well-Architected framework security pillar, it lay

These principles aren't cloud-specific - they're what good security looks like when you can finally implement it properly."

For beginners: "Start with strong identity and automation - get MFA everywhere and let code manage your configurations."

For intermediate practitioners: "Focus on traceability and defense in depth - if you can't see what's happening in real-time, you're flying blind."

Advanced perspective: "Embrace the 'keep people away from data' principle and go hard on automation - build systems that operate securely without human intervention."

Thanks Matt, yes, its good to remember that for all the differences, when it comes to security, cloud is not special, the same principles should apply everywhere.

We always like to get some information from our customers and peers in the security space, so what are you biggest headaches? Hit the chat, what is it that keeps you up at night?

While those are rolling in, Matt, now we've introduced the landscape, let's turn to the question at hand. CNAPP - Cloud-Native Application Protection Platform. Everyone says you need one, but what actually IS it? And how does bundling tools together in a CNAPP help?

8 The core idea of a CNAPP is to bring together a suite of tools in a platform that supports security operations across your cloud

But its not just tool consolidation, CNAPP correlates critical indicators from diverse sources into cohesive, actionable insights with a singular, prioritized view of cloud risk."

For beginners: "Think of CNAPP as solving four big problems: you can't see everything across multiple clouds, you don't know what to fix first, security and development teams don't communicate well, and fixing things takes forever. CNAPP brings all your cloud security tools together so you get one clear picture instead of juggling dozens of different dashboards."

For intermediate practitioners: "The key operational benefits you gain: correlation between configuration findings and vulnerability scans, real-time threat detection that scales with your infrastructure for both VM and container workloads, automated remediation workflows, and integration with your existing ITSM tools. Instead of correlating alerts from five different tools, you get one prioritized action list."

Advanced perspective: "Look for platforms that offer risk correlation across your entire estate; on prem, cloud and container – and not just tool aggregation. The goal is transforming risk mitigation from reactive to proactive through business context led prioritization and automated response workflows."

"Let's talk about MOVEit in 2023 - a breach that perfectly illustrates why tool fragmentation kills security programs. 2,100+ organizations affected, 77+ million records exposed. Attackers targeted a widely used file transfer utility, exploiting a classic SQL injection vulnerability that gave them access to end user files.

Here's what makes this story interesting: The ClOp ransomware group initially exploited this as a zero-day, but the real damage came after a CVE was published and patches were released. While Progress Software quickly issued fixes, most organizations failed to patch their MOVEit instances in time. This turned from a zero-day problem into a classic vulnerability management failure.

The attack was particularly devastating because many organizations didn't even know they had MOVEit instances running in their cloud environments, making both discovery and patching impossible. The MOVEit breach exposed a fundamental problem: organizations had multiple security tools, but couldn't answer two basic questions: 'Where are all our MOVEit instances?' and 'How critical is this vulnerability to our environment?'

Here's how the failure cascade actually happened. Asset discovery failed - inventory tools didn't track all cloud instances. Shadow IT strikes again. Vulnerability management was fragmented - patch management couldn't correlate findings across environments. Risk assessment was disconnected from reality - CVSS scores ignored actual asset criticality and exposure. Response coordination collapsed - security teams couldn't prioritize remediation across complex infrastructure.

Each tool had a piece of the puzzle, but no one could see the complete picture of exposure and risk. CNAPP integration would have changed everything: unified asset discovery across all cloud environments, correlated vulnerability data with actual business impact, and automated risk prioritization based on real-world context, not just CVSS scores."

In the Qualys CNAPP, and the wider ecosystem that's part of the same platform, you'd have full searchable software bill of materials and critical alerts on the asset hours after the CVE was published, thanks to CWP and our Vulnerability management solution that shares the same data. TotalCloud would be triggering insights based on public exposure of the workload and the critical, remotely exploitable CVE, complete with risk scores and an attack path visualization.

10 CIAPP solves the MOVEit problem by creating a unified view of your asset data across all your clouds, workloads, and security

Expert nugget: "The goal isn't perfect security - it's actionable security. When your Posture Management finds a misconfiguration, your Vulnerability Management shows how vulnerable the affected workloads are, and your CDR highlights if it's being actively exploited - all in a single tool."

For beginners: "The early gains are simple - get visibility of your assets and their deployment context, then get more sophisticated as you enrich your data."

For intermediate practitioners: "When selecting a CNAPP, keep in mind integration APIs and data export capabilities. You'll want to connect findings to your existing workflows and ticketing systems."

Advanced perspective: "Evaluate the platform's ability to create custom rules and remediations. The out-of-box functionality is where you start - you need a tool that can adapt as your maturity level grows."

99 as we've seen, one of the main drivers for CNAPP solutions is to try get a grip on tool sprawl and alert fatigue. Curious again

With sprawling tools, alert fatigue is real. So how do you move from drowning in alerts to actually preventing problems?' In preparing today's webinar we've both been looking at various studies and papers, and one that stuck in my mind is the Forrester study that found today's security teams get 11,000 alerts per day on average. That's not security - that's noise.

12 So I'm sure a scenario like this will sound very familiar to many people on the call today:

Your CSPM tool generates 2,500 misconfiguration alerts. Your vulnerability scanner finds 8,000 issues across your three cloud environments. Your SIEM throws another 500 threat indicators at you. Add in CloudTrail logs, container security alerts, and identity anomalies, and you're looking at what Forrester research confirms - north of 11,000 alerts per day (Forrester analysis, 2024) fighting for your attention. Remember this in on average across the enterprise, some will have many more.

Here's what happens next – again, I'm sure this sounds familiar. An alert arrives, your security team starts investigating. But to understand the real impact, they have to switch between five different tools to gather context. While they're trying to figure out how to prioritize this finding without unified risk context, ten new alerts have already arrived. By the time they respond to the original alert, they're already behind. This cycle repeats until your team burns out and real threats slip through the cracks.

19 how does CNAPP solve this operational nightmare? Three fundamental changes transform your security workflow.

First, automated asset discovery replaces manual inventory. CNAPP maps your environment through API polling and log ingestion across all your cloud providers. New resources detected automatically.

Gartner research shows shadow IT accounts for 30-40% of enterprise IT spending, we all know how easy it is for your cloud deployments to sprawl - CNAPP finds what you're missing.

Second, contextual risk scoring replaces the CVSS “everything high or critical” scenario. Instead of treating every vulnerability alert the same, CNAPP combines vulnerability data with actual exposure and business impact. Those 11,000 alerts become 50 prioritized actions that actually matter. Your developers get clear guidance - 'Fix this first because it's internet-facing, has a critical vulnerability and your automated rules have given it high business criticality because its tagged as part of your payment platform'

Third, integrated remediation eliminates tool-hopping, deploy a patch to fix the issue immediately, or remediate a security group to close off access to ports that shouldn't be open. Build rules so that low-risk findings get remediated automatically, or automatically raise and close tickets in your ITSM tool.

Traditional workflow: Alert appears, log into five different tools, manually correlate data, create ticket, wait for development. Time to resolution: two to three weeks. CNAPP workflow: Risk-prioritized notification with easy access to full context, automated ticket creation with clear remediation instructions. Time to resolution: two to three hours.

So now I'd like to talk about a breach that didn't involve a vulnerability or even an attacker. It's the result of not having proper c

In May 2023, A large automotive manufacturer discovered that a simple cloud configuration error had exposed 2.15 million customers' personal data for nearly a decade - from 2013 to 2023. Vehicle location information, ID numbers, personal user data - all sitting there accessible because someone misconfigured their cloud services that handled vehicle connectivity and customer data.

Here's what makes this story fascinating from an operational perspective. This wasn't a sophisticated attack. No advanced persistent threat, no zero-day exploit, no social engineering. Just human error in cloud configuration that went undetected for ten years.

The exact details of the operational failure haven't been published by Toyota, but the Cloud Security Alliance published analysis:

First, and most obviously, inadequate cloud posture management. Yes, there are use cases for exposing storage accounts publically, but had they been using a CNAPP or CSPM tool properly. There is no way this could languish for a decade without being subject to repeated audit against policies and mandates. Beyond that, where was the identity control that limited access to this data and the ability to decrypt it to only the systems that needed it to satisfy the business requirement?

Think about what this tells us about fragmented operations in large companies. We know Toyota had cloud infrastructure teams managing configurations, and they had security teams running vulnerability assessments. But clearly, this wasn't sufficient to be aware of this posture failure and the resulting risk of data leak.

This is the perfect example of why CNAPP isn't just about better security tools - it's about easing operational constraints for security teams working in complex organizations. Automation, being always "audit ready", have a clear view of any exceptions granted to controls for solid business reasons and tool support for ongoing review of those exceptions. Instead of ten years of exposure, we're talking minutes same day detection and response."

In Qualys TotalCloud we'd be alerting on any exposed storage account or publically accessible data store. Even if you'd added an exception for a solid business reason, this would be clear in your reporting and all exceptions are time limited, prompting you to reassess, is this public exposure really supposed to be there?

Thanks for that, very interesting. Particularly the focus on remediation, an often overlooked part of the picture. Sumedh, our C

So given that one of the key outcomes of CNAPP is the ability to take action, let me ask the audience, how long is it taking you to remediate faults in your environment? Answers in the chat as usual please.

Alright, we've covered the what, why, and how of CNAPP. Now for the most important question: You're convinced, but where do you actually start? What do you suggest for a Monday morning action plan?

17 Now we're laying out a classic 30/60/90 type plan, and that in real life things never go this smoothly. No of us know what is g

Look, I know you're eager to start fixing things, but let's start smart. So, quick wins. Enable the free stuff - Azure Policy free tier, GCP Security Command Center standard edition. Make sure you have basic activity monitoring with CloudTrail, Azure Activity Log, Cloud Audit Logs. Start shifting left with CI/CD security scanning - There are basic security features in lots of Dev Ops pipeline tools. Sure, free tier tools are often lacking key features, but it's better than having nothing at all. So if it's there already, switch it on.

Week two start mapping the landscape. What's your current cloud footprint across all providers - AWS, Azure, GCP, whatever you're running. Look at every security tool you have and what it's actually telling you. Look for overlaps and gaps. This is good time to start documenting, but keep it high level, powerpoint or similar is your friend at this point. Don't try to make big changes yet, just understand what you have. I guarantee you'll find resources and tool features you forgot about.

Week three is where it gets strategic. Identify your crown jewels - your most critical systems and data. A lot of organizations will know them intuitively, but it makes a difference when you try to write them down, you'll likely find different teams see this very differently. See if you have any visibility of which systems can actually access those crown jewels. You might be surprised at how little you know. Document your current alert volume too. This becomes your baseline - where you are today versus where you want to be.

Week four is about use case mapping. Identify your important security controls and mandates - what compliance requirements are you actually trying to meet? Map required tool integrations - what systems absolutely need to talk to each other? Identify gaps and blindspots you must cover. This sets you up for intelligent tool selection, not random purchases.

Once you're past that point and if you want to start looking to CNAPP tools to bring it all together, start looking what's out there. Don't get stuck in analysis paralysis, start doing some PoCs. It's always way more interesting to evaluate a tool using your own data, instead of some demo environment.

Decide on the tool that satisfies your use cases at a price point that makes sense for your organization. What features are truly must-haves and which are nice-to-haves?

Then from there start to fly, and see your security team begin to move at the speed of development. Start focusing on understanding and reducing real risk, rather than counting CVEs or percentage compliant.

18 I'd like to close Let's be honest about what makes CNAPP implementations easy or difficult. I'd say that its hard for CNAPP to

The organizations that succeed understand they're not starting from zero. You've already invested in security tools - don't throw that away. Smart CNAPP implementation builds on what's working and fills the gaps. Don't buy expensive CNAPP features you'll never use because they didn't take time to understand your actual requirements first.

Successful teams also get developers involved early, not as an afterthought. When developers feel ownership in the security process, adoption happens naturally. And here's the key - those early wins in efficiency win friends with Devs. Every time automation saves someone an hour, every vulnerability that gets fixed faster because you can give them clear instructions, backed with clear justifications for the priority, is building confidence you're not going to burn their valuable feature development time on fixes that don't achieve anything.

Some ways teams have issues with CNAPP implementation, and to be honest, these failings are really just tool or infrastructure implementation failures in general. CNAPP, like any complex tool, is not something you drop on an organization from on high as an isolated "this will fix everything" deployment. It needs to integrate into your broader security and technology ecosystem.

Beware the complexity trap. Often clear, simple and good enough, wins out over complicated feature sets that are difficult to operationalise. This is less about tool selection and more about what features of your CNAPP will you deploy first, not everything needs to happen day 1.

The worst mistake? Treating this as purely a technology project without a clear business case. Your CFO doesn't care about theoretical security improvements - they care about measurable business outcomes. Make sure this is foremost in your mind, what business outcome are you achieving for this spend?

Final take away and I can't stress this enough - the "perfect security mindset" is a problem in itself. Don't think CNAPP will magically solve every security problem from day one. That's not how this works. CNAPP is about building better security operations, not achieving security perfection, you'll never fix it all. Start with your most critical business risks, and expand from there."

Download the GigaOm Radar for Container Security

See Why Qualys Was Named a
Leader and Outperformer



"We've covered four critical aspects of CNAPP today. Key takeaways:"

Modern security requires modern thinking - Moving from static, manual practices to dynamic, automated ones

Unified platforms solve real problems - CSPM, CWPP, and CDR integration eliminates tool fragmentation like we saw with MOVEit

Operations transformation matters most - Moving from alert chaos to risk-driven workflows

Start Monday with a plan - 30-60-90 day roadmap turns strategy into action

Final Thoughts

"If you remember one thing: In cloud, perfect security is impossible, but good enough security is achievable. Focus on that will reduce risk for your most important cyber assets, automate what you can, and build bridges between security and development teams.

Good luck on Monday morning!

